SETH DAVIES-PATRICK - [redacted]
JAVIER DIAZ-ALISTE - [redacted]
EDWARD GOSDEN - [redacted]

CSE2SIA Assessment 3 — Medibank 2022 Data Breach

Medibank is one of Australia's largest health insurers, holding highly sensitive personal and health information for millions of Australian customers. In August of 2022, Medibank suffered a major data breach in which an attacker allegedly exfiltrated data belonging to 9.7 million current and former customers, including Medicare numbers, health claims information, and, for some international students, their passport numbers were taken *(OAIC, 2024; ACSC, 2022)*. The incident raised serious concerns for customer privacy, confidentiality, and trust in Medibank's ability to safeguard sensitive data. This report examines how the breach occurred, evaluates the associated security risks, and recommends prioritised controls. It argues that weak remote access authentication and poor alert escalation were the primary failures and that layered, defence-in-depth controls could have reduced both the likelihood and impact of the incident.

Medibank's 2022 breach began when malware on a third-party contractor's personal device stole VPN credentials saved to a personal browser profile *(alleged; OAIC, 2024; Cornejo, 2025)* - a risk endpoint monitoring could have caught it. The attacker tested these credentials on 12 August and successfully logged into Medibank's VPN on 23rd August, which required only a password or device certificate rather than multi-factor authentication (alleged), a preventive gap that could have blocked access outright, an inexpensive fix that would have averted a costly incident. Alerts generated on the 24–25 August sat unescalated *(alleged)*, a documented SOC failure *(Tariq et al., 2025);* earlier triage would have caught it. This let the attacker move through the environment laterally and locate customer data largely undetected the whole time *(inferred);* segmentation of systems could have saved this issue. Around 520GB was exfiltrated between 25 August and 13 October before a high-severity alert was finally triaged on 11 October *(alleged)*; earlier escalation could have limited this exfiltration window. The attacker then made extortion contact on the 19-22 October *(alleged)*, and data was published onto the dark web from 9th November *(confirmed; ACSC, 2022).* DLP and network traffic monitoring might have reduced what was exposed.

Based on the attack path above, six risks were identified and rated for likelihood and impact on a scale of 1 to 5, using Medibank’s controls as they were in August 2022. The top risk is the compromise of third-party credentials combined with password-only VPN access (Likelihood: 5, Impact: 5, Score = 25), ranked first because every other risk depended on it. Once the contractor’s credentials were stolen, there was no second factor to stop the attacker from getting in. Mass exfiltration of customer data also scores 25 and ranks second, since this is where confidentiality was actually lost for 9.7 million people (OAIC, 2024). Unescalated alerts rank third (Likelihood: 5, Impact: 4, Score = 20) as they didn't cause the breach, but they let the

attacker stay in the network for around seven weeks, giving them more time to steal data and increasing the damage being done. Extortion and dark web publication (Likelihood: 4, Impact: 5, Score = 20) is ranked above regulatory exposure (Likelihood: 5, Impact: 4, Score = 20) for ethical reasons, as customers are the ones who suffer the consequences despite having no control how Medibank secured their data. The published data included Medicare numbers, passport numbers and health claims information (ACSC, 2022), and unlike a password, a person's health history cannot be reset, leaving them open to stigma, discrimination, denial of future claims, and identity fraud; this places a huge responsibility on Medibank that goes beyond just the law. Regulatory exposure is close to certain, with the Office of Australian Information Commissioner (OAIC) alleging a breach of APP 11.1 and penalties of up to $2.22 million per contravention (OAIC, 2024). Integrity and availability risk is the lowest (Likelihood: 2, Impact: 4, Score = 8) as no data alteration was reported, although admin-level access means records could have been changed or encrypted.
Remote access authentication addresses Risk 1 (credential compromise, score = 25). Medibanks VPN accepted only a password or device certificate (alleged). This preventive control supports confidentiality and interacts with PAM as a second layer. Phishing Restraint MFA (FIDO2) cuts compromise risk by over 99%, even with leaked credentials (Meyer et al., 2023), and is cheap to deploy; zero trust network access (ZTNA) instead would replace the VPN system entirely, better limiting lateral movement but requiring a costlier migration. FIDO2 MFA is the stronger immediate fix, with ZTNA as an upgrade that can happen in the future.

Detection and alerting address Risk 3 (unescalated alerts, score = 20), which let the attacker remain undetected and unsuspected for seven weeks. This detective control supports confidentiality and availability by shortening the exposure window. In house SIEM plus a dedicated SOC team gives full control but is costly and prone to the alert fatigue failure Medibank has already experienced (Tariq et al., 2025); managed detection and response (MDR) outsources triage, improving response speed at the cost of third party reliance. MDR is the stronger choice given Medibanks demonstrated triage fatigue.
Third party and privileged access controls also address Risk 1 (credential compromise, score = 25). A contractor's admin credentials were saved to a personal browser profile and stolen by malware (alleged; OAIC, 2024). This preventive control supports confidentiality as a second layer behind MFA. Privileged access management (PAM) vaults admin credentials and issues them in real time, making stolen passwords close to worthless; supplier review instead relies on contract clauses and audits, fitting the Govern function of NIST CSF 2.0 (NIST, 2024) but depending on contractors following the rules. PAM is the stronger choice, with supplier review kept as a compensating control.

Network segmentation addresses Risk 2 (mass exfiltration, score = 25), where around 520 GB was taken over seven weeks (alleged). This preventive control supports confidentiality by limiting lateral movement into customer databases. DLP with egress monitoring would flag bulk data leaving under the Detect function (NIST, 2024), but depends on the same alert triage that failed in Risk 3; segmentation works without anyone needing to respond. Segmentation is the stronger choice, with DLP layered behind it.

SETH DAVIES-PATRICK - [redacted]
JAVIER DIAZ-ALISTE - [redacted]
EDWARD GOSDEN - [redacted]

While Medibank's breach highlighted the technical security failures, it also demonstrated shortcomings in organisational governance. Under the APP 11.1, entities are required to take "reasonable steps" to protect the individuals' personal information, the parameters of which will depend on the sensitivity of the data they hold and the likelihood of a breach occurring (OAIC, 2024). As Australia's largest health insurer, Medibank is entrusted to hold highly sensitive health records for the organisation's 9.7 million members, which means that the "reasonable steps" would constitute insufficient protection (alleged; OAIC, 2024). The organisation's controls were also not adequately embedded into the broader business process, as standard cybersecurity frameworks such as NIST CSF 2.0 and ISO/IEC 27001 all suggest that the Implementation of controls should be informed by the risk management framework, while the response to the incident pointed to the lack of any assigned ownership for cyber risks, a basic level of which could be seen in the NIST CSF 2.0's Govern function and ISO/IEC 2700's treatment of controls as continuous processes requiring regular reviews. Finally, beyond the legal requirements, Medibank had an ethical duty of care to its customers by virtue of holding their highly sensitive health information, and both frameworks assist in fulfilling this duty by embedding cybersecurity risk management into the continuous delivery of services through dedicated ownership and documentation.

Medibank's 2022 cybersecurity breach was caused not by one but by several factors that chained together, with the first of them being the most critical. The threat actor used stolen third-party credentials to reach the target's network because no second authentication factor was in place, a gap the organisation could have closed by implementing the FIDO2 standard. It took weeks of monitoring before the intruder managed to establish persistent access to the target's network and exfiltrate the highly sensitive health data of 9.7 million people. The four most critical controls described in this document could have prevented the attack by eliminating each of the existing and potential vulnerabilities. The FIDO2 multifactor authentication (MFA) solution, when combined with privileged access management (PAM), would have stopped the initial compromise. Managed detection and response (MDR) and network segmentation would have limited the attacker's impact and persistence. These controls could only be maximally effective when appropriately governed by cybersecurity frameworks such as NIST CSF 2.0 and ISO/IEC 27001. Medibank was legally obligated to ensure the confidentiality, integrity, and availability of its customers' health data under the Australian Privacy Principles (APP) 11.1. In addition, the organisation had an ethical obligation to its customers who were dependent on the company to adequately safeguard their sensitive personal information.

SETH DAVIES-PATRICK - [redacted]
JAVIER DIAZ-ALISTE - [redacted]
EDWARD GOSDEN - [redacted]

Implementation Plan

Stage	Action	Owner	Dependancies/challenges
Immediate (0-3 months)	Enforcing phishing-resistant MFA (FIDO2) on VPN/remote access	IT/IAM team	Hardware token rollout to staff + third-party contractors; budget sign-off
Medium term (3-13 months)	Stand up SOC/MDR with defined alert triage SLAs; segment admin network from customer data	CISO office / SOC	MDR vendor selection; integration with existing SIEM; staff retraining
Ongoing	Regular PAM reviews of third party/privileged access; DLP + egress monitoring tuning; annual ISO 27001 audit; NIST CSF governance reporting to board	GRC team + Board Risk Committee	Sustained budget; ongoing board engagement

CSE2SIA ASSESSMENT 3

Medibank 2022 Data Breach

Name	Student number
[Seth Davies-Patrick]	[ ]
[Javier Diaz-Aliste]	[ ]
[Eddie Gosden]	[ ]

SECTION 1 - OVERVIEW (SETH)

Medibank 2022 Incident

- Australia's largest health insurer, holding sensitive personal and health data for millions of customers
- August 2022: an attacker allegedly exfiltrated data belonging to 9.7 million current and former customers (alleged; OAIC, 2024)
- Data allegedly included Medicare numbers, health claims information, and passport numbers for some international students (ACSC, 2022)
- Primary failures: weak remote-access authentication and poor alert escalation

9.7M

Customers affected (OAIC,2024)

SECTION 2 - ATTACK PATH (SETH)

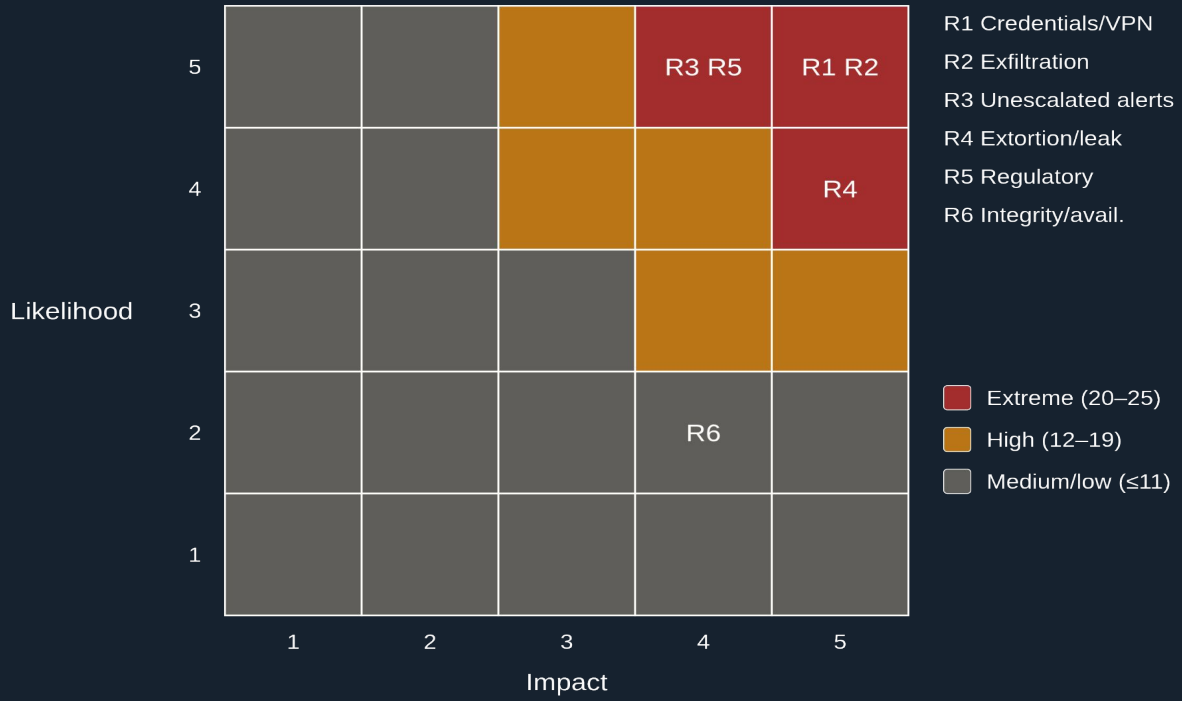
Attack Path

- A single stolen credential, left unguarded by MFA, gave an attacker seven weeks of undetected access before 520GB of health data was exfiltrated and published.



SECTION 3 - RISK ANALYSIS (JAVIER)

Risk Analysis | Risk Matrix



SECTION 3 - RISK ANALYSIS (JAVIER)

Risk Analysis | Risk Register

ID	Risk	L	I	Score	Rating
R1	Credential theft + password-only VPN	5	5	25	Extreme
R2	Mass exfiltration of customer data	5	5	25	Extreme
R3	Alerts not triaged/escalated	5	4	20	Extreme
R4	Extortion, publication, customer harm	4	5	20	Extreme
R5	Regulatory, legal, reputational	5	4	20	Extreme
R6	Data alteration/encryption (inferred)	2	4	8	Medium

- Credential compromise and mass exfiltration are the top risks, one enabled the breach, the other is where 9.7M customers data was lost.
- Unescalated alerts let the attacker stay for around 7 weeks.

- Customer harm ranks above regulatory exposure on ethical grounds. Health data cannot be reset.
- Integrity/availability risk is inferred, no alteration of data was reported.

SECTION 3 - IMPACTS (JAVIER)

CIA, privacy and stakeholder impacts

Confidentiality

520GB exfiltrated (alleged); 9.7M customers affected (OAIC, 2024a). Names, DOBs, Medicare numbers, passport numbers and health claims data published (ACSC, 2022).

Integrity

No data alteration reported, but admin-level access means claims records could have been changed.

Availability

Seven weeks of undetected access meant systems could have been encrypted or disrupted.

Stakeholder Impacts

Customers

Health history can't be reset; exposed to stigma, discrimination and identity fraud

International Students

Passport numbers exposed (ACSC, 2022)

Medibank

Alleged APP 11.1 breach, up to $2.22M per contravention (OAIC, 2024b); loss of trust

3rd Party Contractors

Raises supplier accountability.

Regulators

OAIC proceedings ongoing; lower confidence in health data protection

SECTION 4 - RISK ANALYSIS (SETH & JAVIER)

Control weaknesses & recommended controls

PREVENTIVE

Remote Access Authentication

- FIDO2 MFA now (99%+ compromise reduction, Meyer et al., 2023); ZTNA as a medium-term upgrade replacing the VPN

DETECTIVE

Detective & Alerting

- MDR preferred: in-house SIEM+SOC missed exactly this alert (Tariq et al., 2025); MDR gives faster triage without added staffing

PREVENTIVE

Privileged & Third-Party Access

- Privileged Access Management: vaulted real-time admin credentials make stolen passwords close to worthless.

PREVENTIVE

Network Segmentation

- Segmentation preferred: limits lateral movement into customer database without relying on alert triage; DLP + egress monitoring layered behind it under NIST CSF Detect (NIST, 2024).

SECTION 5 - GOVERNANCE (EDDIE)

Governance, ethics & framework mapping

APP 11.1

“Reasonable steps” scale with data sensitivity and org size - Medibank's scale raised the bar.

NIST CSF 2.0 - Govern

Assigns board level accountability and ties controls like MFA and segmentation to named owners

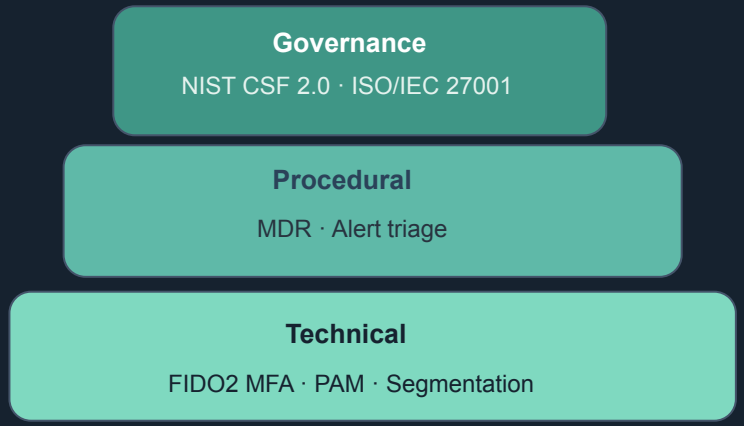
ISO/IEC 27001 - ISMS

Requires a documented risk treatment plan and regular audits - not “set and forget”.

Beyond compliance: *Medibank held an ethical duty of care to 9.7 million customers who had no way to protect their own health data once it was in Medibank’s hands*

SECTION 6 - CONCLUSION (EDDIE)

Layered defence, not a single fix



Layered, governed security - not a single fix - is what would have reduced both the likelihood and impact of this incident.

Root cause: compounding gaps, not one flaw - password-only VPN access, unescalated alerts, and unvaulted third party credentials let the attack progress unchecked for roughly seven weeks

REFERENCES

APA7 Reference List

1. Australian Cyber Security Centre. (2022). *Medibank Private cyber security incident*. https://www.cyber.gov.au/about-us/alerts/medibank-private-cyber-security-incident
2. Cornejo, G. M. (2025). Third-party risk in U.S. health care ransomware incidents: Business associate involvement and breach size. *Health and Technology*. https://doi.org/10.1007/s12553-025-01036-9
3. Meyer, L. A., Romero, S., Bertoli, G., Burt, T., Weinert, A., & Ferres, J. L. (2023). How effective is multifactor authentication at deterring cyberattacks? *arXiv*. https://doi.org/10.48550/arXiv.2305.00945
4. Office of the Australian Information Commissioner. (2024). *Medibank data breach: Alleged timeline*. https://www.oaic.gov.au/__data/assets/pdf_file/0037/228979/Medibank-data-breach-alleged-timelineinfographic.pdf
5. Office of the Australian Information Commissioner. (2024). *OAIC takes civil penalty action against Medibank*. https://www.oaic.gov.au/news/media-centre/oaic-takes-civil-penalty-action-against-medibank
6. Tariq, S., Chhetri, M. B., Nepal, S., & Paris, C. (2025). Alert fatigue in security operations centres: Research challenges and opportunities. *ACM Computing Surveys, 57*(9), Article 224. https://doi.org/10.1145/3723158
7. NIST. (2024). The NIST cybersecurity framework (CSF) 2.0. The NIST Cybersecurity Framework (CSF) 2.0, 2.0(29). https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
8. OAIC. (2019, July 22). *Chapter 11: APP 11 security of personal information*. Office of the Australian Information Commissioner. https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-11-app-11-security-of-personal-information
9. OAIC. (2024, June 5). *OAIC takes civil penalty action against medibank*. OAIC. https://www.oaic.gov.au/news/media-centre/oaic-takes-civil-penalty-action-against-medibank
10. Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0. *NIST*. https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20
11. International Organization for Standardization. (2022). *ISO/IEC 27001 standard – information security management systems*. ISO. https://www.iso.org/standard/27001